**Name: Muhammad Usama Bilal**

**Roll Number :CSI-B1-460**

**INSTRUCTOR: MUHAMMAD SAAD**

**Date: 24-3-206**

# 1.0 Project Introduction

# 1.1 Project Summary

The document outlines a Purple Team lab focused on network protocol abuse and security testing. It includes performing DoS attacks like SYN Flood and ICMP Flood to understand how systems become overwhelmed. Students must capture and analyze network traffic using Wireshark or tcpdump and document the results with screenshots. The lab also covers MITM attacks using ARP spoofing with Ettercap to study traffic interception and vulnerabilities. Finally, it emphasizes defense strategies and evaluating future threats like DoS/DDoS in real-world environments.

**Protocol Analysis (Key Outcomes):**

- Analyze network traffic using tools like Wireshark/tcpdump
- Identify different protocols (TCP, ICMP, ARP) in captured packets
- Detect abnormal patterns such as SYN Flood or ICMP Flood attacks
- Understand how data flows between devices in a network
- Recognize vulnerabilities in network communication
- Improve skills in monitoring and securing network traffic

## Task 01: Denial of Service (DoS) Simulations :

-

**Gemini said**

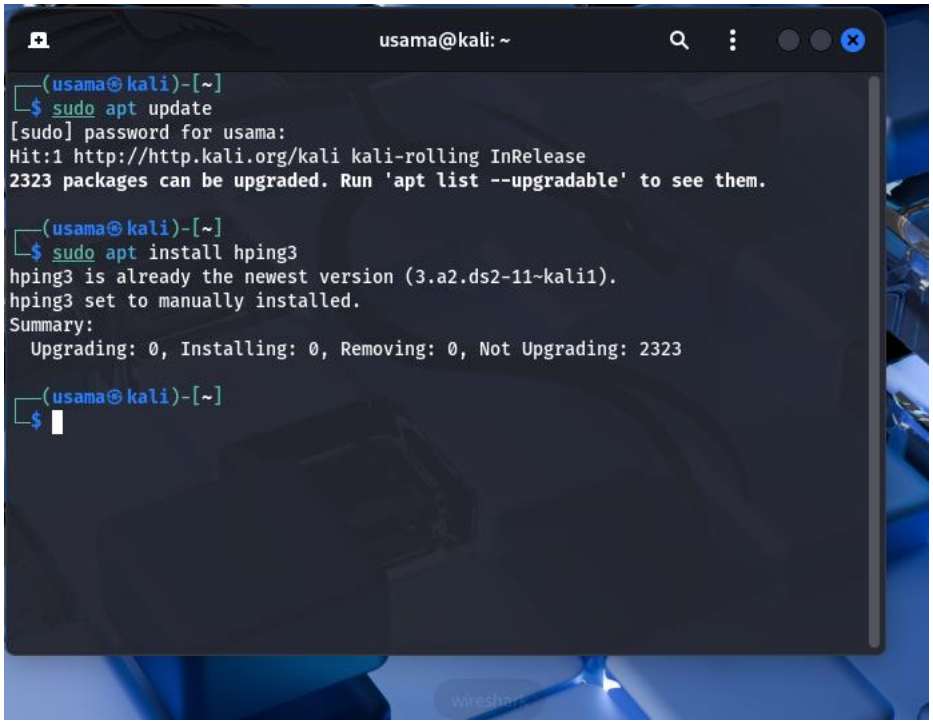
It looks like you've already completed the first step of your task: installing hping3 on your Kali Linux machine! Since you need to document this for a technical report, I've structured the response to address the core concepts of DoS vs. DDoS and provided the specific commands you need to execute the next steps of your simulation.

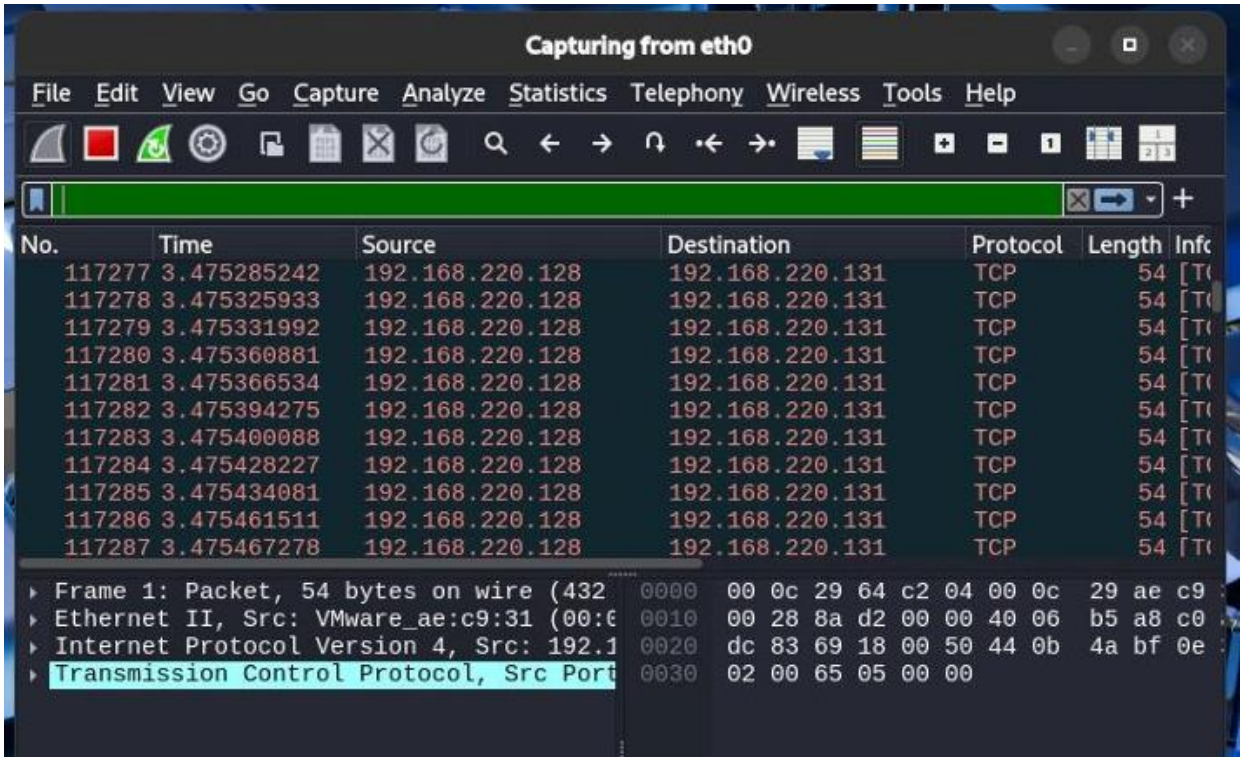
---

**1. Differentiating DoS and DDoS Architectures**

In a technical context, the primary difference lies in the **source** and **scale** of the attack.

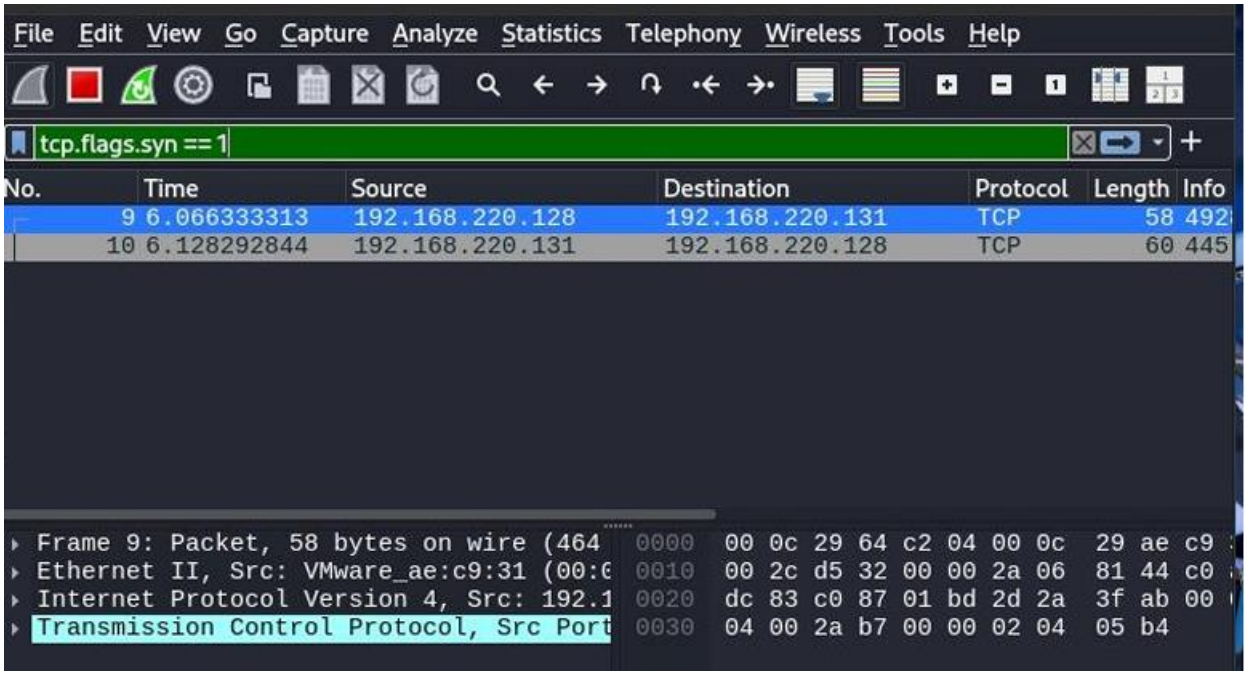
- **DoS (Denial of Service):** A one-on-one battle. A single attacker, using a single internet connection and one machine, attempts to overwhelm a target. It is often easier to block because the defender only needs to identify and filter out one malicious IP address.
- **DDoS (Distributed Denial of Service):** A "many-on-one" onslaught. The attacker uses a **Botnet**—a network of thousands of compromised devices (zombies) scattered globally. Because the traffic comes from thousands of different sources simultaneously, it is significantly harder to mitigate without accidentally blocking legitimate users.

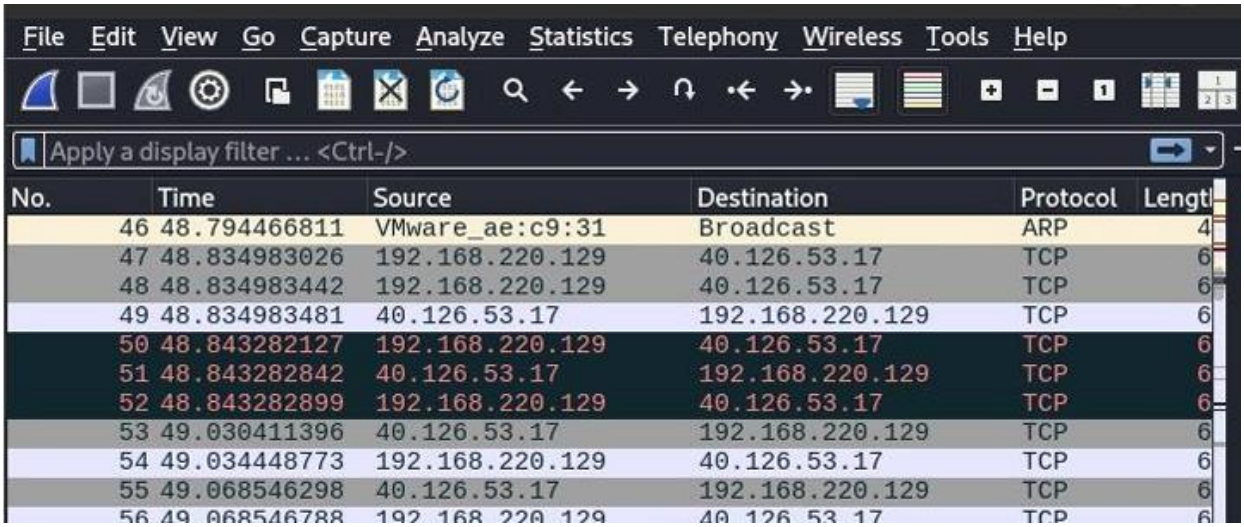





## 2.3 ICMP Flood with Spoofed IP:

An ICMP Flood with spoofed IP addresses was performed by generating a large number of ICMP Echo Request packets with randomly altered source IPs. This technique hides the attacker’s real identity, making it difficult to trace the origin of the attack. As the target system attempts to respond to these fake requests, its outgoing bandwidth and resources become heavily consumed. This results in network congestion and degraded performance, potentially leading to denial of service for legitimate users.



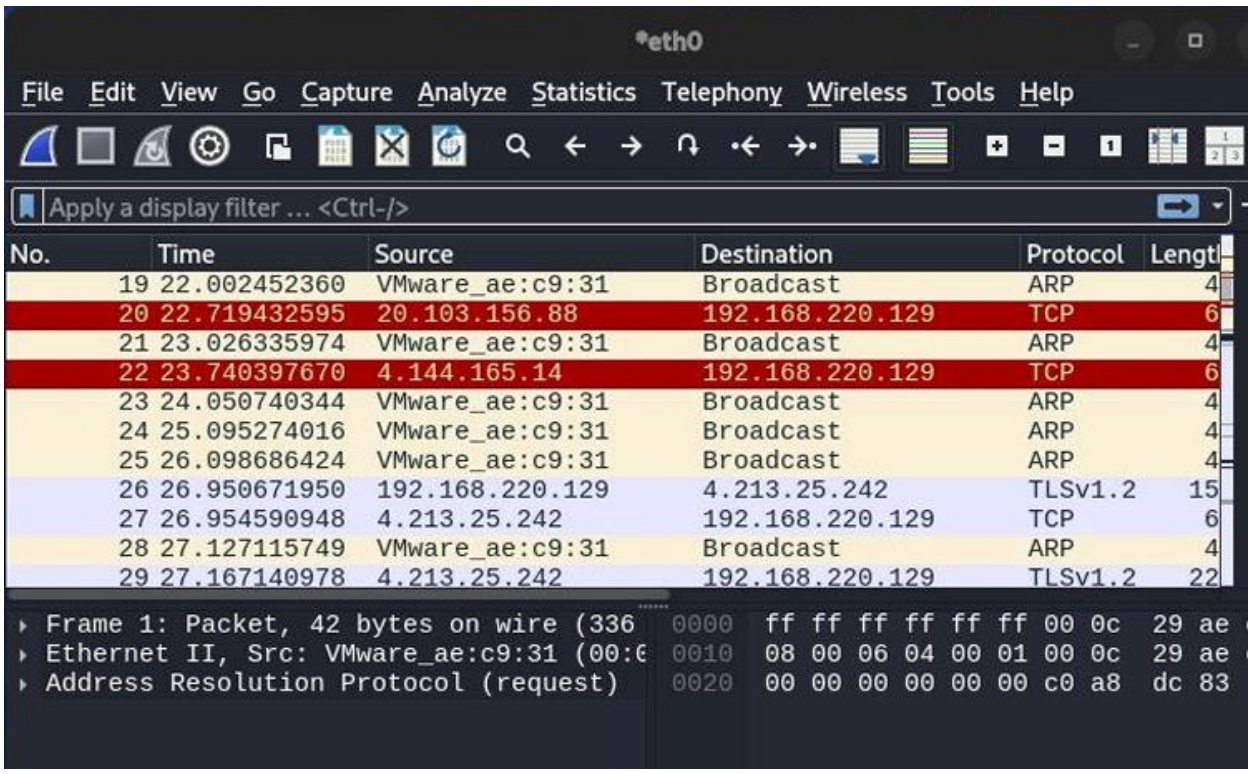

| No. | Time | Source | Destination | Protocol | Length |
|---|---|---|---|---|---|
| 46 | 48.794466811 | VMware_ae:c9:31 | Broadcast | ARP | 4 |
| 47 | 48.834983026 | 192.168.220.129 | 40.126.53.17 | TCP | 6 |
| 48 | 48.834983442 | 192.168.220.129 | 40.126.53.17 | TCP | 6 |
| 49 | 48.834983481 | 40.126.53.17 | 192.168.220.129 | TCP | 6 |
| 50 | 48.843282127 | 192.168.220.129 | 40.126.53.17 | TCP | 6 |
| 51 | 48.843282842 | 40.126.53.17 | 192.168.220.129 | TCP | 6 |
| 52 | 48.843282899 | 192.168.220.129 | 40.126.53.17 | TCP | 6 |
| 53 | 49.030411396 | 40.126.53.17 | 192.168.220.129 | TCP | 6 |
| 54 | 49.034448773 | 192.168.220.129 | 40.126.53.17 | TCP | 6 |
| 55 | 49.068546298 | 40.126.53.17 | 192.168.220.129 | TCP | 6 |
| 56 | 49.068546788 | 192.168.220.129 | 40.126.53.17 | TCP | 6 |

## Task 02: MITM & ARP Spoofing Analysis :

In this task, a Man-in-the-Middle (MITM) attack was performed using ARP spoofing to intercept communication between two victim machines on the same network. The purpose of this task was to understand how attackers can exploit the trust-based nature of the ARP protocol and observe the importance of secure communication methods like HTTPS and VPNs.

Ettercap was installed on Kali Linux and used in CLI mode to launch the ARP spoofing attack. IP forwarding was enabled using the sysctl tool (net.ipv4.ip_forward = 1) to allow the attacker machine to forward packets between the two victims, making it act as an intermediary without interrupting **communication.**

## 3.1 Environment Configuration

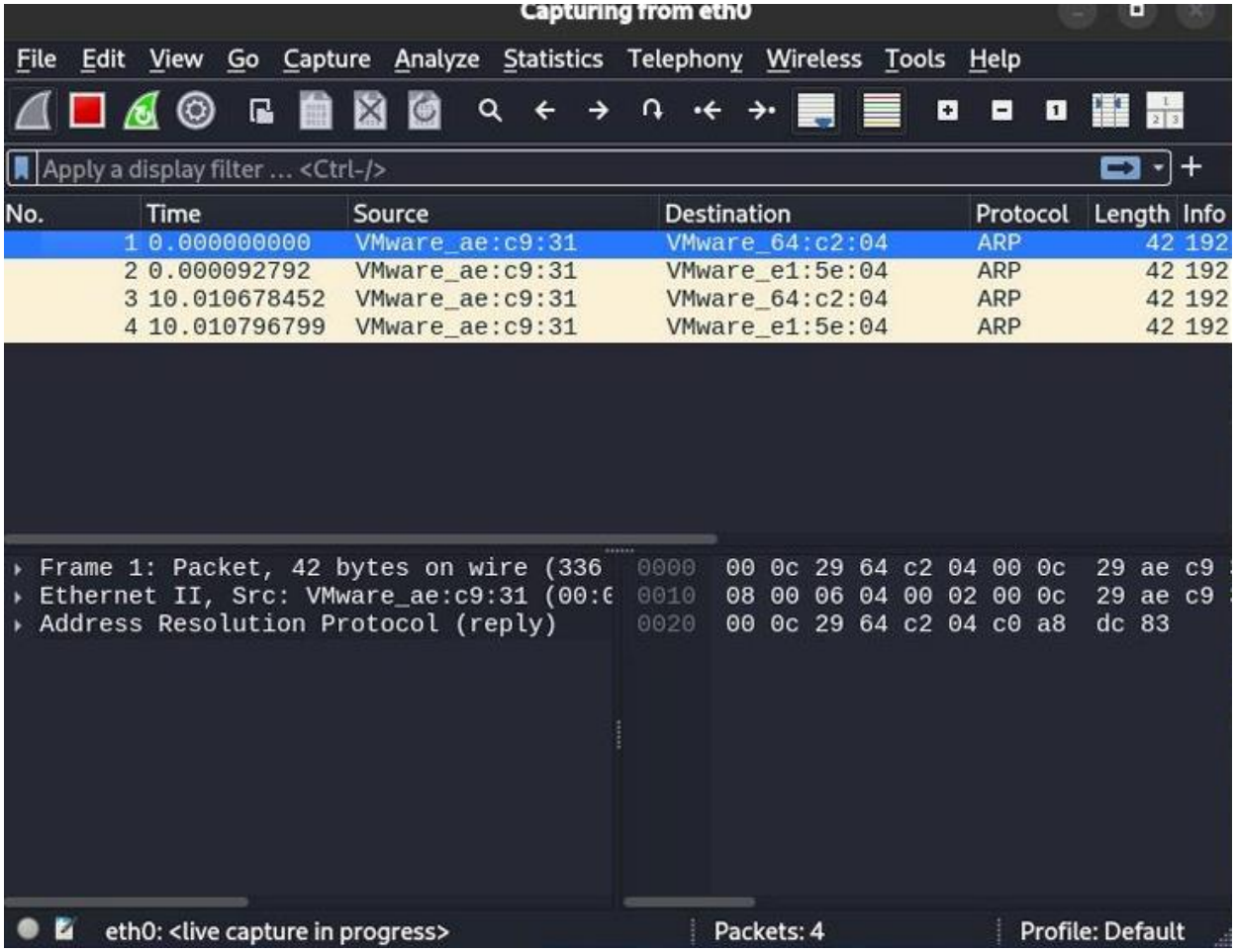



The IP addresses of both victim machines and the attacker machine were identified and verified. Wireshark was used alongside Ettercap to capture and analyze network traffic during the attack. When communication was initiated between the two victim machines using HTTP (port 80), the transmitted data was visible in plain text in Wireshark, demonstrating the insecurity of unencrypted protocols.

When the same experiment was repeated after connecting both victim machines to a VPN, the captured traffic appeared encrypted and unreadable. This highlighted the effectiveness of encryption in protecting sensitive data from interception.

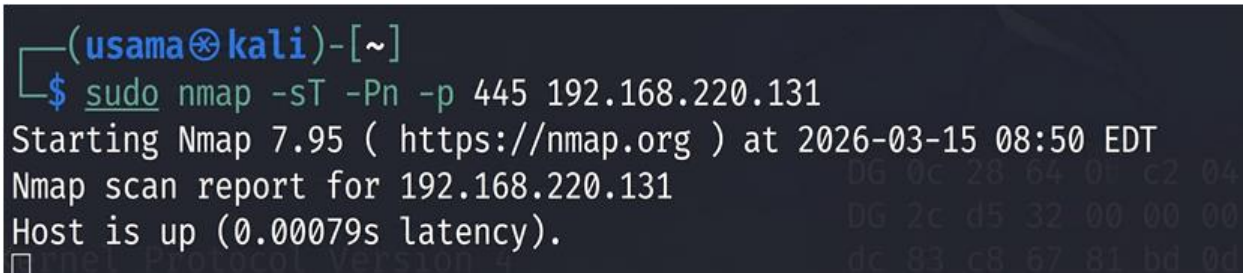
usama@kali: ~

```
  57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Scanning for merged targets (2 hosts)...

* |==================================================>| 100.00 %

2 hosts added to the hosts list...

ARP poisoning victims:

 GROUP 1 : 192.168.220.131 00:0C:29:64:C2:04

 GROUP 2 : 192.168.220.2 00:50:56:E1:5E:04
Starting Unified sniffing...

Text only Interface activated...
Hit 'h' for inline help

┌──(usama㉿kali)-[~]
└─#
```



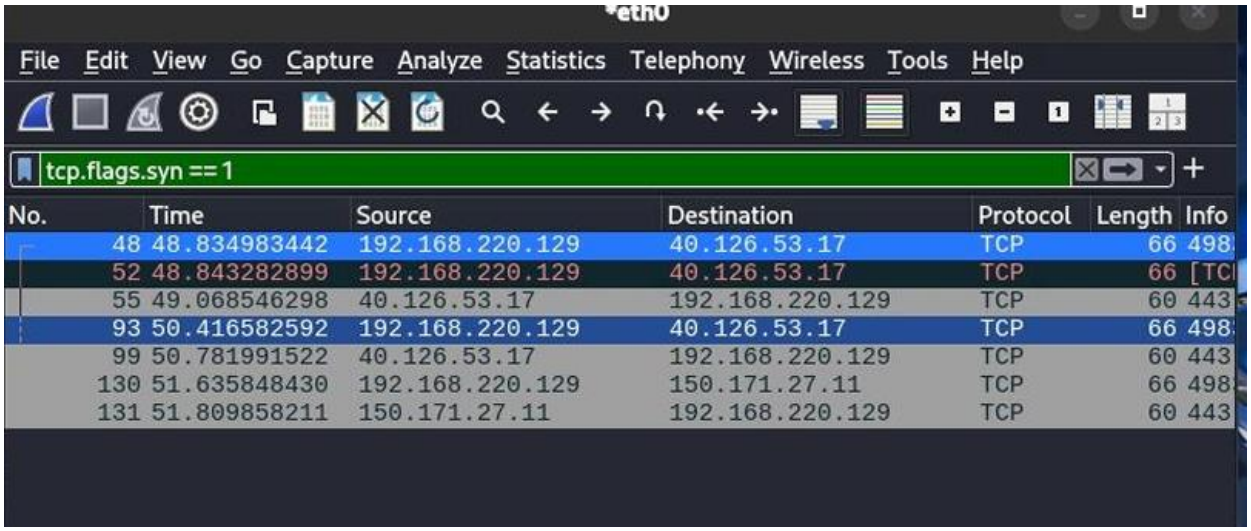

## 3.3 Data Interception Analysis:

HTTP vs. VPN The core of this task was observing how protocol choice affects data privacy.



## 2. Encrypted (VPN):

Once both victims connected to a VPN, the traffic was encapsulated in an encrypted tunnel. While Ettercap could still "see" the packets, the content appeared as indecipherable cipher-text (UDP/ESP).




### 4. Final Assessment & Strategic Defense

### 4.1 Key Insights and Vulnerabilities

The lab exercise highlights a critical architectural flaw: foundational network protocols like ARP operate on a basis of implicit trust, lacking native authentication mechanisms. This "trust-by-default" model ensures that without additional security layers—such as end-to-end encryption (TLS/HTTPS) or tunneled traffic (VPNs)—all data transmitted across a local segment remains exposed to any malicious actor sharing the same network.

### 4.2 Navigating Risks in Shared Environments

Interception threats, such as Man-in-the-Middle (MITM) attacks, represent a significant danger in untrusted or public environments (e.g., airports, cafes, and open coworking spaces). Since these infrastructures often lack robust client isolation, an adversary can easily position themselves as an intermediary to monitor or manipulate traffic.

---

**Security Hardening Recommendations**

- **Implement Encrypted Tunneling (VPN):** Utilizing a Virtual Private Network ensures that even if traffic is intercepted, the underlying data remains encapsulated in a secure, encrypted tunnel that is unreadable to unauthorized parties.
- **Enforce Protocol Encryption (HTTPS-Only):** Leverage HSTS (HTTP Strict Transport Security) or browser-level enforcement to block all unencrypted connections, ensuring data integrity during transit.
- **Mitigate SSID Spoofing:** Disable automatic connection features for saved networks to prevent devices from silently joining rogue access points or spoofed "Evil Twin" hotspots.
- **Static ARP Configuration:** For high-security internal environments, implementing static ARP entries for critical infrastructure (like gateways) can effectively neutralize poisoning attempts.